SilesiaID

Analiza prawna, compliance i zgodność z EUDI Wallet

Dokument wewnętrzny projektu · Wersja 1.0 · Kwiecień 2026 · ETHSilesia, Katowice

Zakres dokumentu	Status projektu	Cel dokumentu
Analiza prawna od dnia 1 wdrożenia	Hackathon MVP → Pilot produkcyjny	Checklist compliance od dnia zero

> *Ten dokument stanowi wewnętrzną analizę prawną projektu SilesiaID. Nie jest opinią prawną w rozumieniu przepisów o świadczeniu pomocy prawnej. Przed wdrożeniem produkcyjnym zalecana jest weryfikacja przez radcę prawnego lub adwokata specjalizującego się w prawie cyfrowym i ochronie danych.*

1. Mapa regulacyjna — ramy prawne SilesiaID

SilesiaID funkcjonuje na przecięciu pięciu odrębnych obszarów prawa. Każdy z nich nakłada konkretne obowiązki od pierwszego dnia działania, nie dopiero od momentu osiągnięcia skali. Poniższa mapa porządkuje regulacje według pilności działania.

Regulacja	Obszar	Pilność dla D+1	Kluczowy wymóg
RODO / GDPR (UE 2016/679)	Ochrona danych osobowych	KRYTYCZNA	Podstawa prawna przetwarzania, DPIA, polityki retencji
eIDAS 2.0 (UE 2024/1183)	Tożsamość cyfrowa i podpis el.	WYSOKA — szansa	Zgodność z W3C VC → kompatybilność z EUDI Wallet do 2026
AMLD6 / AML (UE 2018/843)	Przeciwdziałanie praniu pieniędzy	WYSOKA	Nie jesteś instytucją AML, ale partnerzy (PKO) mają obowiązki
Ustawa KRS / CEIDG (PL)	Rejestry gospodarcze	ŚREDNIA	Warunki dostępu API, zakaz komercyjnego odsprzedaży danych
MiCA (UE 2023/1114)	Kryptoaktywa	NISKA — monitoring	SBT/Soulbound Token ≠ kryptoaktywo, ale wymaga weryfikacji
NIS2 (UE 2022/2555)	Cyberbezpieczeństwo	ŚREDNIA	Przy skali — wymogi dla operatorów usług cyfrowych
Prawo umów (KC)	Relacje B2B	KRYTYCZNA	Regulamin, ToS, umowy z instytucjami weryfikującymi
Ustawa o świadczeniu usług el. (PL)	Usługi elektroniczne	KRYTYCZNA	Wymóg regulaminu i polityki prywatności przed startem

2. RODO / GDPR — analiza szczegółowa dla SilesiaID

2.1 Jakie dane przetwarza SilesiaID i jaki jest ich status prawny

Kluczowe rozróżnienie dla całej architektury prawnej SilesiaID to podział danych na dwie kategorie o zupełnie różnym statusie RODO:

Kategoria danych	Przykłady	Status RODO	Podstawa prawna
Dane firm z rejestrów publicznych	NIP, nazwa, adres, forma prawna, status	POZA RODO (dane podmiotów, nie osób)	Art. 6 ust. 1 lit. e) — interes publiczny rejestrów
Dane beneficjentów rzeczywistych (CRBR)	Imię, nazwisko, PESEL właściciela	DANE OSOBOWE — pod RODO	Art. 6 ust. 1 lit. c) — obowiązek prawny (AML)
Dane właściciela konta SilesiaID	E-mail, telefon, historia logowań	DANE OSOBOWE — pod RODO	Art. 6 ust. 1 lit. b) — wykonanie umowy
Hash NIP / Hash KRS na blockchainie	keccak256(NIP), keccak256(KRS)	PSEUDONIMIZACJA — szara strefa RODO	Wytyczne EDPB 02/2025 — wymaga analizy
Logi weryfikacji (kto i kiedy skanował)	IP, timestamp, ID instytucji	DANE OSOBOWE (jeśli powiązane z osobą)	Art. 6 ust. 1 lit. f) — uzasadniony interes

WAŻNE: Polski organ nadzorczy (UODO) wydał pierwsze w UE decyzje dotyczące danych z KRS i CEIDG — orzekł, że dane z rejestrów publicznych dotyczące firm (nie osób fizycznych prowadzących jednoosobową działalność) są poza zakresem RODO jako dane podmiotów, nie osób naturalnych. Jednak CEIDG zawiera dane osobowe przedsiębiorcy (imię, nazwisko, adres zamieszkania = siedziba). To wymaga dodatkowej ostrożności.

2.2 Blockchain a prawo do bycia zapomnianym — główne ryzyko

Największym napięciem prawnym między SilesiaID a RODO jest niezmienność danych na blockchainie (Ethereum) versus prawo do usunięcia danych (art. 17 RODO). Analiza ryzyka:

RYZYKO	Na Ethereum mainnet/Sepolia raz zapisany hash NIP nie może być usunięty. Jeśli keccak256(NIP) zostanie uznany za dane osobowe przez UODO lub EDPB, SilesiaID naruszy art. 17 RODO.

MITYGACJA	EDPB w wytycznych 02/2025 uznaje, że kryptograficzny hash (bez możliwości odwrotnego przekształcenia) może stanowić wystarczające pseudonymizowanie/anonimizowanie. Kluczowe: keccak256(NIP) + sól (salt) minimalizuje ryzyko re-identyfikacji. Polska UODO nie zajęła stanowiska wobec keccak256 NIP.

ZALECENIE	Architektura off-chain first: blockchain przechowuje WYŁĄCZNIE hashe z saltą. Żadnych danych osobowych on-chain. Revoke() nie usuwa danych — oznacza certyfikat jako nieważny. Dane osobowe właściciela konta w tradycyjnej bazie danych z pełnym RODO compliance.

2.3 DPIA — ocena skutków dla ochrony danych

Ocena skutków dla ochrony danych (DPIA, art. 35 RODO) jest obowiązkowa lub silnie zalecana dla SilesiaID z następujących powodów:

- Systematyczne monitorowanie zachowań na dużą skalę (historia weryfikacji)
- Przetwarzanie danych beneficjentów rzeczywistych z CRBR (dane wrażliwe kontekstowo)
- Nowe technologie: blockchain + Account Abstraction + dane z rejestrów publicznych
- Dane dotyczące działalności gospodarczej mogą prowadzić do profilowania firm

> *Rekomendacja: Przeprowadź uproszczone DPIA przed pilotażem z PKO Bank. Dokument ten powinien zostać przygotowany przez osobę z certyfikatem CIPM/CIPP lub prawnika i udostępniony PKO jako dowód dojrzałości compliance. PKO Bank jako instytucja nadzorowana przez KNF będzie go wymagać.*

2.4 Checklist RODO dla dnia pierwszego wdrożenia (D+1)

#	Wymóg RODO	Działanie	Status MVP
1	Polityka prywatności (art. 13/14)	Opublikuj na silesia.id/privacy przed uruchomieniem	MUST HAVE
2	Regulamin serwisu	Zawiera: cel, zakres, prawa użytkownika, podstawa prawna	MUST HAVE
3	Zgoda na e-mail marketing (art. 6/7)	Checkbox opt-in, granularne zgody, możliwość wycofania	MUST HAVE
4	Rejestr czynności przetwarzania (art. 30)	Tabela: kategoria danych / cel / okres retencji / podmiot	MUST HAVE
5	Minimalizacja danych (art. 5)	Nie zbieraj więcej niż niezbędne do weryfikacji NIP	MUST HAVE
6	Umowy powierzenia (art. 28)	Z Railway (hosting), Privy (auth), Vercel (frontend)	MUST HAVE
7	Retencja danych	Zdefiniuj: konto aktywne = dane; konto usunięte = 30 dni grace	MUST HAVE
8	Prawo do usunięcia konta	Przycisk w panelu: usuwa dane off-chain; certyfikat revoke on-chain	MUST HAVE
9	DPIA	Uproszczona wersja przed pilotażem z PKO	SHOULD HAVE
10	Inspektor ochrony danych (DPO)	Nieobowiązkowy przy małej skali, zalecany przy pilotażu bankowym	NICE TO HAVE

3. eIDAS 2.0 i EUDI Wallet — analiza kompatybilności i szansa

3.1 Stan prawny eIDAS 2.0 na dzień wdrożenia

Data / Zdarzenie	Co się stało / co nastąpi	Wpływ na SilesiaID
20 maja 2024	eIDAS 2.0 (UE 2024/1183) wchodzi w życie	Mamy pewność co do ram prawnych — architekturę buduj pod ten standard
Koniec 2025	Pierwsze implementing acts (standardy tech.) opublikowane	Specyfikacje W3C VC i ARF zatwierdzone — SilesiaID może je implementować
24 grudnia 2026	Każde państwo UE musi udostępnić EUDI Wallet obywatelom	Polska musi mieć wallet — SilesiaID może być pierwszym prywatnym certyfikatem kompatybilnym
Grudzień 2027	Banki i PSP muszą akceptować EUDI Wallet jako metodę auth	PKO Bank jest prawnie zobowiązany przyjąć EUDI — integracja SilesiaID staje się strategiczna
2030 (docelowo)	Pełna adopcja EUDI Wallet w sektorze publicznym i prywatnym	SilesiaID w pełni zintegrowany z EUDI — lub zastąpiony jego publiczną warstwą

OKNO STRATEGICZNE: Polska nie opublikowała harmonogramu wdrożenia EUDI Wallet. Deadline 24 grudnia 2026 jest realnie zagrożony (większość państw UE jest opóźniona). SilesiaID ma 18–24 miesiące jako jedyne działające rozwiązanie w Polsce zgodne z tym standardem. To nie jest hipoteza — to potwierdzony przez KE stan pilotaży.

3.2 Wymagania techniczne eIDAS 2.0 a architektura SilesiaID

eIDAS 2.0 definiuje konkretne standardy techniczne dla kwalifikowanych portfeli cyfrowych. Analiza kompatybilności:

Wymóg eIDAS 2.0	Specyfikacja techniczna	Status SilesiaID MVP	Działanie
Verifiable Credentials	W3C VC 2.0 / JSON-LD	PLANOWANE (V1 po hackathonie)	Implementuj W3C VC od początku, nie jako afterthought
Selective Disclosure	SD-JWT lub BBS+ signatures	NIE ZAIMPLEMENTOWANE	Wymagane przed pilotażem instytucjonalnym
Decentralized Identifiers	DID (W3C DID Core)	CZĘŚCIOWO (Privy wallet = DID)	Formalizuj DID method dla SilesiaID
Poziom bezpieczeństwa	LoA High (eIDAS Art. 8)	NIE SPEŁNIONE (email OTP = LoA Substantial)	MVP OK dla pilotażu; LoA High = biometria w V2
Interoperability ARF	EUDI Architecture Reference Framework	ZGODNE ARCHITEKTURALNIE	Dokumentuj zgodność z ARF v1.4
Brak centralnego repozytorium	Privacy by design, dane lokalnie	CZĘŚCIOWO (hash on-chain, dane off-chain)	Dane firmy nigdy nie trafiają na blockchain

Wymóg eIDAS 2.0	Specyfikacja techniczna	Status SilesiaID MVP	Działanie
Kwalifikowany dostawca (QTSP)	Rejestracja w krajowym nadzorcy	NIE DOTYCZY MVP	Rozwaz w V3 przy skali - daje status qualified

3.3 Elektroniczne Poświadczenia Atrybutów (EAA) — kluczowa szansa

eIDAS 2.0 wprowadza nową kategorię: Electronic Attestations of Attributes (EAA) — kryptograficznie podpisane dowody cech firmy, które mogą być wystawiane przez podmioty prywatne (nie tylko rząd). To jest dokładnie tym, czym jest certyfikat SilesiaID.

Co eIDAS 2.0 definiuje jako EAA	Jak SilesiaID to realizuje
Kryptograficznie weryfikowalny dowód atrybutu (np. 'firma aktywna')	SBT na Ethereum z hashem NIP + status aktywności z CEIDG/KRS
Selective disclosure — ujawniasz tylko to, co konieczne	Do zaimplementowania w V1 przez SD-JWT (konieczne przed instytucjami)
Może być wystawiony przez podmiot prywatny (non-QTSP)	SilesiaID Sp. z o.o. = prywatny wydawca EAA — to wystarczy na start
Importowalny do EUDI Wallet gdy dostępny	W3C VC format = gotowy do importu. Implementacja eksportu do JSON-LD w V2

4. Analiza prawna dostępu do polskich rejestrów publicznych

4.1 Warunki prawne korzystania z API rejestrów

SilesiaID agreguje dane z pięciu polskich rejestrów publicznych. Każdy z nich ma odrębny reżim prawny dostępu i ograniczeń w komercyjnym wykorzystaniu danych.

Rejestr	Podstawa prawna dostępu	Ograniczenia	Ryzyko dla SilesiaID
CEIDG	Ustawa o CEIDG (Dz.U. 2011 nr 116 poz. 678), art. 39 — dane jawne	Zakaz sprzedaży danych z CEIDG jako produktu / baza danych	ŚREDNIE: weryfikacja NIP OK, sprzedaż bazy CEIDG NIE
KRS	Ustawa o KRS (Dz.U. 2020 poz. 568), art. 8 — dane jawne	Odsprzedaż wyciągów ze znacznikiem KRS wymaga zgody MS	NISKIE: SilesiaID nie sprzedaje wyciągów, hash tylko
Biała Lista VAT	Art. 96b Ustawy VAT — dane jawne z obowiązku	Brak ograniczeń dla celów weryfikacji kontrahenta	BRAK ryzyka dla modelu SilesiaID

Rejestr	Podstawa prawna dostępu	Ograniczenia	Ryzyko dla SilesiaID
CRBR	Ustawa AML (Dz.U. 2018 poz. 723), art. 67 — dane jawne	Dane UBO to dane osobowe — RODO obowiązuje w pełni	WYSOKIE: dane beneficjentów = dane osobowe z RODO
REGON	Ustawa o statystyce publicznej — dane jawne	Wymagana rejestracja w GUS; dane do celów statystycznych	NISKIE: weryfikacja formatu NIP/REGON — standardowe

KRYTYCZNE dla MVP: SilesiaID NIE sprzedaje danych z rejestrów. Certyfikat to dowód że weryfikacja MIAŁA MIEJSCE, nie kopia danych z rejestru. Ten model jest fundamentalnie różny od Transparent Data lub Ondato, które sprzedają dostęp do danych. To rozróżnienie jest kluczowe zarówno prawnie, jak i jako przewaga konkurencyjna.

4.2 MiCA i status prawny SBT (Soulbound Token)

Soulbound Token (SBT) wystawiany przez SilesiaID jest kluczowym elementem technicznym, ale może budzić pytania regulatorów o status jako kryptoaktywo. Analiza:

Kryterium MiCA	Stan SBT SilesiaID	Ocena
Czy SBT jest wymienialny?	NIE — blokada transferFrom(), safeTransferFrom()	Nie jest aktywem finansowym
Czy SBT ma wartość rynkową?	NIE — nieprzenośny, brak rynku wtórnego	Wyłączony z definicji e-money token
Czy SBT jest instrumentem płatniczym?	NIE — certyfikat tożsamości, nie waluta	Poza zakresem MiCA
Czy SBT jest papierem wartościowym?	NIE — brak praw majątkowych, dywidend, udziałów	Poza zakresem MiFID II
Co SBT reprezentuje?	Dowód ukończenia weryfikacji tożsamości firmy	Bliżej: certyfikat cyfrowy niż kryptoaktywo

WNIOSEK	SBT SilesiaID nie jest kryptoaktywem w rozumieniu MiCA. Jest cyfrowym certyfikatem weryfikacji — prawnie bliżej podpisowi elektronicznemu lub znacznikowi kryptograficznemu niż tokenu kryptowalutowego. Rekomendacja: przygotuj 1-stronicową opinion letter od prawnika specjalizującego się w blockchain przed rozmową z KNF lub KNF-nadzorowanymi instytucjami.

5. Compliance od dnia pierwszego — master checklist

Poniższy checklist definiuje co MUSI być gotowe zanim SilesiaID przyjmie pierwszego użytkownika (kolumna D+1), co musi być gotowe przed pilotażem z bankiem (D+90) i co w wersji produkcyjnej (D+365).

5.1 D+1 — przed uruchomieniem MVP / hackathon

#	Obszar	Konkretne działanie	Odpowiedzialny
1	Prawo umów	Opublikuj Regulamin Serwisu i Politykę Prywatności na silesia.id	Założyciel
2	RODO — podstawa prawna	Określ podstawę prawną dla każdej kategorii danych (art. 6/9 RODO)	Założyciel
3	RODO — przejrzystość	Klauzule informacyjne art. 13 przy rejestracji i zbieraniu e-maila	Dev Frontend
4	RODO — powierzenie	Umowy DPA z: Vercel, Railway, Privy, Alchemy (dostawca RPC)	Założyciel
5	Rejestry	Sprawdź ToS API CEIDG i KRS — potwierdź że Twój model nie narusza	Założyciel
6	Spółka	Zarejestruj spółkę (sp. z o.o.) przed jakąkolwiek umową pilotażową	Założyciel
7	Bezpieczeństwo	Nie commituj kluczy prywatnych do git; użyj .env + secrets manager	Dev Backend
8	Smart contract	Adres kontraktu Sepolia opublikuj publicznie — weryfikowalność = zaufanie	Dev Blockchain
9	Cookies	Baner cookie z granularnymi zgodami (Analytics opcjonalne, niezbędne OK)	Dev Frontend

5.2 D+90 — przed pilotażem z PKO Bank / TAURON

#	Obszar	Konkretne działanie	Priorytet
1	RODO — DPIA	Przeprowadź i udokumentuj ocenę skutków dla ochrony danych (DPIA)	KRYTYCZNY
2	AML — pozycja prawna	Uzyskaj opinion letter: SilesiaID NIE jest instytucją AML/obligatem	KRYTYCZNY
3	MiCA — SBT opinion	Opinion letter: SBT ≠ kryptoaktywo — 1 strona, podpisana przez prawnika	WYSOKI
4	Umowa pilotażowa	LOI lub Pre-Agreement z PKO: zakres, dane, SLA, exit clause	WYSOKI
5	ISO 27001 gap analysis	Nie musisz mieć certyfikatu, ale banking partner będzie pytał o security	WYSOKI
6	eIDAS — EBSI registration	Zarejestruj się jako uczestnik EBSI Ecosystem (bezpłatne, ważne politycznie)	ŚREDNI
7	W3C VC	Zaimplementuj pełny W3C VC 2.0 format dla certyfikatu (zamiast custom JSON)	KRYTYCZNY
8	SD-JWT	Selective disclosure: firma może ujawnić tylko 'aktywna VAT' bez NIP	WYSOKI
9	Audyt smart contractu	Certik lub Hacken — wymagany przez każdą instytucję regulowaną	WYSOKI

#	Obszar	Konkretne działanie	Priorytet
10	Polityka retencji	Udokumentuj: jak długo, gdzie, co usuwasz i kiedy z każdej bazy	WYSOKI

5.3 D+365 — wersja produkcyjna, ścieżka do skali

Obszar	Wymóg	Uzasadnienie
Rejestracja jako wydawca EAA	Aplikacja do CERT.PL lub UODO jako wydawca elektronicznych poświadczeń atrybutów	eIDAS 2.0 — formalny status wydawcy EAA
NIS2 compliance	Jeśli >50 pracowników lub krytyczna infrastruktura: rejestracja pod NIS2	Przy skali — obowiązek prawny
QTSP path (opcjonalnie)	Ocena opłacalności ubiegania się o status Qualified Trust Service Provider	Daje 'qualified' status certyfikatom — mocniejszy prawnie
Cross-border — Czechy/Słowacja	Analiza prawna lokalnych rejestrów i warunków API	Ekspansja geograficzna wymaga lokalnej analizy
EUDI Wallet export	Implementacja exportu certyfikatu do formatu EUDI Wallet (JSON-LD)	Gotowość na wdrożenie rządowego EUDI Wallet
Audyt zewnętrzny RODO	Roczny audyt compliance przez zewnętrznego audytora	PKO Bank i inne instytucje regulated będą wymagać

6. Zestawienie porównawcze: SilesiaID vs. rynek vs. wymogi prawne

Poniższa tabela zestawia kluczowe wymogi prawne i compliance z aktualnym stanem SilesiaID oraz pozycją konkurentów rynkowych. Służy jako narzędzie due diligence dla rozmów z partnerami instytucjonalnymi.

Wymóg prawny / compliance	SilesiaID MVP	Transparent Data	Sumsub/Ondato	EUDI Wallet (rządowy)
Zgodność z RODO	Wymaga wdrożenia (checklist sekcja 5)	Tak (usługa dojrzała)	Tak (certyfikowany)	Tak (mandatoryjny)
W3C Verifiable Credentials	Planowane V1 (architektura gotowa)	NIE	Częściowo	TAK (wymagane)
Selective Disclosure	Planowane V1 przez SD-JWT	NIE	NIE	TAK (wymagane)
Certyfikat przenośny dla firmy	TAK — kluczowa przewaga	NIE	NIE	TAK (cel systemu)

Wymóg prawny / compliance	SilesiaID MVP	Transparent Data	Sumsub/Ondato	EUDI Wallet (rządowy)
Audyt smart contractu	Wymagany przed produkcją	N/A (brak blockchain)	N/A	N/A
AML opinion letter	Wymagany D+90	Posiada	Posiada (instytucja AML)	Rządowy — nie dotyczy
eIDAS LoA	Substantial (e-mail) → High (V2)	N/A	Substantial–High	High (wymagane)
Dostęp do CEIDG/KRS API	TAK — bezpośrednia integracja	TAK — bezpośrednia	TAK — pośrednia	Planowany
Status EAA Issuer (eIDAS 2.0)	Możliwe jako podmiot prywatny	Nie planuje	Nie planuje	QTSP (rządowy)
Działanie transnarodowe UE	Planowane V3 przez EBSI	Ograniczone	TAK (komercyjnie)	TAK (cel systemu)
Koszt weryfikacji dla instytucji	Ułamek kosztu (model SaaS)	0,50–2 PLN/zapytanie	5–15 EUR/weryfikacja	Bezpłatny (po wdrożeniu)

Interpretacja tabeli: SilesiaID w dniu hackathonu jest projektowo bliżej EUDI Wallet (architektura W3C VC, off-chain dane, certyfikat po stronie firmy) niż jakikolwiek komercyjny gracz na rynku. Komercyjni gracze (Sumsub, Ondato) budują w modelu instytucja-płaci, nie firma-posiada. Rządowy EUDI Wallet nie istnieje produkcyjnie. To jest lukra.

7. Mapa ryzyk prawnych i mitygacja

Ryzyko	Prawdopodob.	Skutek	Mitygacja	Horyzont
UODO uznaje hash NIP za dane osobowe	NISKIE	Konieczna zmiana architektury on-chain	Hash z saltą + off-chain primary; konsultacja z UODO proaktywna	D+180
KRS / CEIDG API zablokuje komeryjne zapytania	NISKIE	Utrata dostępu do danych źródłowych	Cache 30 min; redundancja: CEIDG + api.rejestry.net; umowa API	D+30
KNF uzna SBT za instrument finansowy	BARDZO NISKIE	Obowiązek rejestracji jako podmiot nadzorowany	Opinion letter prawna + Soulbound = nieprzenośny = nie instrument	D+90
EUDI Wallet wdrożony szybciej niż 2026	NISKIE	Rząd 'wyprzedza' SilesiaID	Kompatybilność W3C VC = uzupełnienie, nie zastąpienie	D+365
Naruszenie danych osobowych (breach)	ŚREDNIE	Kara UODO do 4% obrotu; utrata zaufania	ISO 27001 przygotowanie; DPA z dostawcami; szyfrowanie at rest	D+1

Ryzyko	Prawdopodob.	Skutek	Mitygacja	Horyzont
PKO Bank odrzuci certyfikat bez akredytacji	ŚREDNIE	Brak anchor partnera = model się nie startuje	Opinia prawna + DPIA + EBSI registration = wystarczające na pilot	D+90
Przepisy AML6 wymagają certyfikacji SilesiaID	NISKIE	Wymóg rejestracji jako instytucja AML	SilesiaID nie jest instytucją AML — wystawia certyfikat, nie przetwarza transakcji	D+180
Pracownik błędnie oznaczy firmę jako 'aktywna'	WYSOKIE (tech)	Liability za błędną weryfikację; roszczenia instytucji	ToS: dane z rejestrów publicznych, brak gwarancji; liability cap	D+1

8. Kluczowe dokumenty prawne do przygotowania — harmonogram

Dokument	Co zawiera	Kiedy	Kto przygotowuje
Regulamin Serwisu SilesiaID	Cel, zakres, prawa/obowiązki stron, liability cap, ToS dla API	D+1 (przed MVP)	Prawnik lub wzorzec + weryfikacja
Polityka Prywatności	Podstawy prawne, kategorie danych, retencja, prawa RODO, DPO	D+1 (przed MVP)	Prawnik lub wzorzec + weryfikacja
Rejestr Czynności Przetwarzania (RCP)	Tabela: dane / cel / podstawa / okres / podmioty	D+1 (wewnętrzny)	Założyciel (nie wymaga prawnika)
Umowy DPA z dostawcami	Privy, Vercel, Railway, Alchemy — standardowe GDPR DPA	D+1	Dostawcy mają szablony — podpisz ich wersję
Klauzule informacyjne (art. 13)	Do wklejenia w UI przy każdym formularzu zbierającym dane	D+1	Dev Frontend + treść od prawnika
Opinion Letter: SBT ≠ MiCA	1–2 strony analizy statusu SBT pod MiCA i MiFID II	D+90	Kancelaria specjalizująca się w blockchain
Opinion Letter: SilesiaID ≠ AML	Analiza: nie jesteśmy instytucją AML, nie pośredniczymy w transakcjach	D+90	Kancelaria specjalizująca się w FinTech
DPIA	Ocena skutków dla ochrony danych z matrycą ryzyk i mitygacją	D+90	Konsultant RODO lub DPO
LOI / Pre-Agreement z PKO Bank	Letter of Intent na pilotaż — zakres, dane, SLA, wyjście	D+90	Prawnik korporacyjny
Umowa API dla instytucji weryfikujących	Warunki dostępu do API /verify, SLA, rate limiting, liability	D+90	Prawnik + Dev
Audyt smart contractu	Raport Certik/Hacken z wynikami i statusem poprawek	D+120	Firma audytorska blockchain

Dokument	Co zawiera	Kiedy	Kto przygotowuje
Polityka Bezpieczeństwa Informacji (PSI)	Zgodna z ISO 27001 — wymagana przez instytucje regulowane	D+180	CISO lub konsultant bezpieczeństwa

9. Wnioski i rekomendacje strategiczne

9.1 Kluczowe wnioski prawne

POZYTYWNY	Model biznesowy SilesiaID (certyfikat przenośny, dane off-chain, hash on-chain) jest fundamentalnie zgodny z RODO i eIDAS 2.0 — nie ma tu sprzeczności strukturalnej.

POZYTYWNY	Certyfikat SilesiaID kwalifikuje się jako Electronic Attestation of Attributes (EAA) pod eIDAS 2.0 — wystawiany przez podmiot prywatny, bez potrzeby statusu QTSP na starcie.

POZYTYWNY	SBT (Soulbound Token) nie spełnia definicji kryptoaktywa pod MiCA ze względu na nieprzenośność i brak wartości rynkowej.

UWAGA	Dane z CRBR (beneficjenci rzeczywiści) są danymi osobowymi pod RODO — wymagają odrębnej podstawy prawnej i pełnego reżimu compliance od dnia pierwszego użycia.

UWAGA	Keccak256(NIP) na blockchainie jest w szarej strefie RODO — EDPB 02/2025 sugeruje że hash z saltą jest wystarczającą pseudonimizacją, ale polskie UODO nie potwierdziło wprost.

RYZYKO	Brak Regulaminu i Polityki Prywatności przy starcie MVP = naruszenie polskiej ustawy o świadczeniu usług drogą elektroniczną. Nie jest to ryzyko hypotetyczne — jest to brak formalny.

9.2 Priorytety na najbliższe 30 dni

1. Zarejestruj spółkę sp. z o.o. (SilesiaID lub inna nazwa) — bez spółki nie podpiszesz umowy pilotażowej z bankiem.
2. Opublikuj Regulamin + Politykę Prywatności przed startem MVP — to minimum prawne, nie negocjowalne.
3. Podpisz umowy DPA z Privy, Vercel, Railway — wymagane przez RODO, standardowe szablony dostępne.
4. Zamów 1-stronicową opinion letter o statusie SBT pod MiCA — inwestycja 2–5 tys. PLN, usuwa ryzyko przed rozmowami z KNF-nadzorowanymi instytucjami.
5. Zarejestruj się w EBSI Ecosystem jako uczestnik — bezpłatne, daje wiarygodność przy rozmowach z PKO i regulatorami.

> *POINTSUMOWANIE: SilesiaID ma unikatową pozycję — jest jedynym działającym polskim projektem zgodnym architekturalnie z eIDAS 2.0 / EUDI Wallet. Okno czasowe przed wdrożeniem rządowego EUDI Wallet to 18–24 miesiące. Compliance nie jest blokerem — jest narzędziem budowania zaufania instytucjonalnego. Każdy dokument prawny z listy w sekcji 8 jest jednocześnie materiałem sprzedażowym dla PKO Bank i TAURON.*

Dokument przygotowany na potrzeby ETHSilesia 2026 · Katowice · Kwiecień 2026

Niniejszy dokument ma charakter roboczy i stanowi wewnętrzną analizę compliance projektu SilesiaID. Nie stanowi porady prawnej w rozumieniu przepisów o świadczeniu pomocy prawnej i nie zastępuje konsultacji z licencjonowanym radcą prawnym lub adwokatem. Autorzy nie ponoszą odpowiedzialności za decyzje podjęte wyłącznie w oparciu o ten dokument.